Manual vs Automated Testing

Bug Bounty Security Guide — When to Use Each Approach & The Hybrid Strategy

1. Overview

Manual testing and automated scanning are complementary approaches in bug bounty. A successful researcher knows when to rely on automation and when to engage manually for deeper analysis.

---

2. Manual Testing Strengths

Manual testing:

- Detects **logic flaws** that scanners can't
- Finds **context-specific vulnerabilities** (e.g., business logic bypass, chained issues)
- Allows creative testing across **multi-step workflows**
- Helps in **bypassing client-side controls** or **tampering with flows**

Examples:

- Skipping steps in checkout
- Reusing verification tokens
- Combining race conditions with authorization flaws

---

3. Automated Scanning Strengths

Automated scanners:

- Are ideal for **broad surface testing** across multiple assets
- Catch **common technical misconfigurations** quickly
- Help identify **low-hanging fruit** such as open directories, missing headers, old software versions

Examples:

- Using **Nuclei** to scan hundreds of endpoints for known CVEs
- Running **httpx** to identify live hosts
- Using **ffuf** to brute-force content paths or parameter names

---

4. When Manual is Better

Use manual testing when:

- The app has **custom workflows**
- You are exploring **state transitions**

- You suspect **logic-based vulnerabilities**
- An app uses **heavy client-side logic** (e.g., JavaScript frameworks like React, Angular)

Manual testing is irreplaceable in:

- Race conditions
- Authentication/authorization testing
- Exploiting chained vulnerabilities

---

5. When Automation is Better

Use automation when:

- Dealing with **mass recon**
- Testing **large scopes**
- Looking for **known patterns and CVEs**
- Performing **wide content discovery**

Example stack:

- subfinder → httpx → gau/waybackurls → ffuf → nuclei → notify

This is efficient for **early-stage recon**.

---

6. The Hybrid Approach

The most effective hunters use both methods:

- **Automate recon and initial scans**
- **Manually analyze interesting targets**
- Use automation to **generate leads**, then go deep manually on promising ones

This saves time while allowing depth where needed.

---

7. Automation Pitfalls

- **False positives:** Scanners may flag non-issues
- **Noise:** Submitting automated reports without analysis leads to poor reputation
- **Missed context:** Logic bugs and flow bypasses won't be detected

Automated tools should assist, not replace, understanding.

---

8. Manual Testing Pitfalls

- **Slow speed:** Manual testing is time-intensive
- **Scope overload:** Without automation, handling large programs is inefficient
- **Inconsistency:** Manual processes may miss paths a scanner would find

Balance is key.

---

9. Strategic Use of Time

A suggested flow:

1. Start with automation to map the surface
2. Use output to shortlist interesting assets
3. Dive manually into each asset for in-depth logic or abuse testing
4. Document workflows, note weak assumptions
5. Revisit targets later as features change

---

10. Key Insight

Automation helps you **find where to look**. Manual testing helps you **find what others missed**. The combination of both is what makes elite bug hunters stand out.